مقيد

شركة القيروان لنظم المعلومات

إجراءات استخدام الذكاء الاصطناعي

وثيقة إجرائية · وثيقة تنفيذية لسياسة استخدام الذكاء الاصطناعي QIS-POL-002

رقم الوثيقة	**QIS-PRC-002**
الإصدار	٠٫٤ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

معلومات الوثيقة

اسم الوثيقة	إجراءات استخدام الذكاء الاصطناعي
رمز الوثيقة	QIS-PRC-002
السياسة الأم	سياسة استخدام الذكاء الاصطناعي — QIS-POL-002 (الإصدار ٠,٦)
مالك الوثيقة	قائد الحوكمة والمخاطر والالتزام — نايف السالم
مُعِدّ الوثيقة	نايف السالم — قائد الحوكمة والمخاطر والالتزام
إصدار الوثيقة	٠,٤ (مسودة)

إشارة المشاركة (Traffic Light Protocol)

صُنّفت هذه الوثيقة وفق بروتوكول الإشارة الضوئية (TLP) المعتمد في وثائق الهيئة الوطنية للأمن السيبراني عند المستوى **برتقالي (TLP:AMBER)**، ولا يجوز تداولها خارج هذا النطاق دون موافقة مالك الوثيقة.

● **أحمر** TLP:RED	شخصي وسري للمستلم فقط: لا يجوز للمستلم مشاركتها مع أي فرد من داخل الجهة أو خارجها خارج النطاق المحدد للاستلام.
● **برتقالي** TLP:AMBER	**مشاركة محدودة: يجوز للمستلم مشاركتها داخل جهته مع الأشخاص المعنيين فقط، ومن يتطلب الأمر منهم اتخاذ إجراء بشأنها.** — المستوى المعتمد لهذه الوثيقة
● **أخضر** TLP:GREEN	مشاركة في نفس المجتمع: يجوز مشاركتها مع الجهة نفسها أو جهة ذات علاقة أو في القطاع نفسه، دون تبادلها أو نشرها عبر القنوات العامة.
● **أبيض** TLP:WHITE	غير محدود.

سجل التعديلات

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠,١	٩ نوفمبر ٢٠٢٦م	نايف السالم	الإصدار الأول، بعد فصل الخطوات التنفيذية عن السياسة QIS-POL-002 وتوسيعها إلى خمسة إجراءات.
٠,٢	٩ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة (الألوان والخطوط وصفحة الغلاف)، وتحسين قابلية القراءة، واعتماد مستويات إشارة المشاركة الأربعة المستخدمة في وثائق الهيئة الوطنية للأمن السيبراني.

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠٫٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	توسيط شارة التصنيف وتلوينها بلون مستواها، وتلوين العلامة المائية، واعتماد اسم الشركة «شركة القيروان لنظم المعلومات».
٠٫٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة. وتحديث الإحالة إلى الإصدار ٠٫٦ من السياسة QIS-POL-002.

مقيد

اعتماد الوثيقة

الدور	المسمى الوظيفي	الاسم	التاريخ	التوقيع
المالك	قائد الحوكمة والمخاطر والالتزام	نايف السالم	—	—
المُراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	—	—
المُراجِع	رئيس تقديم الخدمات	سلطان الدوسري	—	—
المعتمِد	رئيس اللجنة الإشرافية للأمن السيبراني	فيصل الحربي	—	—

جدول المراجعة

معدل المراجعة	تاريخ آخر مراجعة	تاريخ المراجعة القادمة
مع كل تحديث للسياسة الأم، وسنوياً على الأقل	—	نوفمبر ٢٠٢٧م

تصنيف الوثيقة

سري للغاية	تُصنّف الوثيقة «سري للغاية» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم لا يمكن تداركه أو إصلاحه.
سري	تُصنّف الوثيقة «سري» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم، وينطبق على المعلومات الحساسة التي تحدد طريقة عمل الشركة.
مقيد	**تُصنّف الوثيقة «مقيد» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر محدود، وينطبق على المعلومات التي لم تُعتمد للتداول العام خارج الشركة.**
عام	تُصنّف الوثيقة «عام» عندما لا يترتب على الوصول غير المصرح به إليها أو الإفصاح عن محتواها أي أثر على الشركة، وينطبق على الوثائق المعتمدة للنشر العام.

سرية الوثيقة

تعد هذه الوثيقة إحدى وثائق شركة القيروان لنظم المعلومات المصنفة «مقيد»، ويقتصر تداولها على منسوبي الشركة والجهات الحكومية المتعاقدة معها التي تحتاج إلى الاطلاع

عليها، ولا يحق نشرها أو تعديلها أو نشر جزء منها لغير المصرح لهم إلا بموافقة كتابية مسبقة من مالك الوثيقة.

مقيد

جدول المحتويات

١. الغرض

٢. النطاق

٣. العلاقة بالسياسة الأم

٤. الأدوار المشاركة في تنفيذ الإجراءات

٥. خريطة الإجراءات

٦. الإجراء الأول: طلب واعتماد أداة أو حالة استخدام للذكاء الاصطناعي

٧. الإجراء الثاني: تقييم مخاطر الأمن السيبراني لأنظمة الذكاء الاصطناعي

٨. الإجراء الثالث: التطوير الآمن ومراجعة المخرجات والشيفرات المولدة

٩. الإجراء الرابع: إدارة الوصول والصلاحيات لأدوات الذكاء الاصطناعي

١٠. الإجراء الخامس: الاستجابة لحوادث الذكاء الاصطناعي والإيقاف الآمن

١١. متطلبات تمكين وتنفيذ الإجراءات

١٢. مؤشرات قياس الالتزام

١٣. المراجع

مقيد

١. الغرض

تحدد هذه الوثيقة الخطوات التنفيذية التفصيلية التي تترجم بنود سياسة استخدام الذكاء الاصطناعي إلى ممارسات عمل يومية قابلة للقياس والتدقيق، بما يشمل مالك كل خطوة، والمخرج المطلوب منها، والمدة الزمنية لإنجازها، والسجلات الواجب الاحتفاظ بها.

٢. النطاق

تنطبق هذه الإجراءات على جميع إدارات الشركة وموظفيها والمتعاقدين معها، وعلى جميع أدوات ونماذج الذكاء الاصطناعي المستخدمة في الشركة، ومزايا الذكاء الاصطناعي التي تبنيها أو تستضيفها لعملائها، وتشمل كامل دورة الحياة من الطلب والتقييم إلى التشغيل والإيقاف الآمن.

٣. العلاقة بالسياسة الأم

هذه الوثيقة منبثقة من سياسة استخدام الذكاء الاصطناعي QIS-POL-002، ولا تنشئ التزامات جديدة تتجاوزها، وعند التعارض تُقدَّم أحكام السياسة. ويشير كل إجراء إلى أرقام بنود السياسة التي ينفذها، وتُقرأ التعريفات من السياسة مباشرة دون تكرارها هنا.

٤. الأدوار المشاركة في تنفيذ الإجراءات

الدور	المسؤولية في هذه الإجراءات
اللجنة الإشرافية للأمن السيبراني	اعتماد الأدوات وحالات الاستخدام عالية التأثير، وقبول المخاطر المتبقية، ومتابعة تقارير الالتزام الربعية.
قائد الحوكمة والمخاطر والالتزام	تشغيل هذه الإجراءات، وإدارة سجل الأدوات المعتمدة وسجل المخاطر، ومراجعة الالتزام، ورفع التقارير والتصعيد.
العمليات والهندسة الأمنية	تقييم المخاطر، والاختبارات وبوابات المراجعة، ومراجعة الصلاحيات، وقيادة الاستجابة للحوادث مع مركز العمليات الأمنية المُدار.
الرئيس التنفيذي للتقنية	تنفيذ الصلاحيات والإعدادات والتسجيل، ودعم بيئات التشغيل والاستعادة.
فريق التطوير	تطبيق متطلبات التطوير الآمن ومراجعة الشيفرات المولدة واختبارها.
رئيس تقديم الخدمات	التنسيق مع العملاء والحصول على موافقاتهم المكتوبة، وإبلاغهم بالحوادث.

الدور	المسؤولية في هذه الإجراءات
الإدارات الطالبة	تقديم الطلبات المكتملة، وتنفيذ المراحل التجريبية، والالتزام بالضوابط أثناء الاستخدام.

٥. خريطة الإجراءات

تغطي الإجراءات الخمسة دورة حياة استخدام الذكاء الاصطناعي في الشركة بالتسلسل التالي:

١ طلب	٢ تقييم	٣ تطوير	٤ تشغيل	٥ استجابة
رفع الطلب وتقييمه واعتماده	تحليل مخاطر الأمن السيبراني	التصميم الآمن ومراجعة المخرجات	إدارة الوصول والمراقبة	احتواء الحوادث والإيقاف الآمن

الإجراء	المسمى	رقم البند	بنود السياسة المرتبطة
١	طلب واعتماد أداة أو حالة استخدام	٦	QIS-2-4-1 · QIS-9.2.2 · QIS-9.1.2 · QIS-9.1.1 · QIS-4-1-1 · ٦-٢-١
٢	تقييم مخاطر الأمن السيبراني	٧	١-١-١ · ٢-١-١ · QIS-1-1-1 إلى QIS-1-1-3 · ٢-١ إلى ٢-٦-٣
٣	التطوير الآمن ومراجعة المخرجات	٨	المكوّن ٢-١ كاملاً · QIS-1-2-1 إلى QIS-1-2-3 · ٢-٧
٤	إدارة الوصول والصلاحيات	٩	المكوّن ٢-٢ كاملاً · المكوّن ٣-١
٥	الاستجابة للحوادث والإيقاف الآمن	١٠	المكوّن ٢-٨ · ٣-١-١ · QIS-3-1-2 · QIS-3-1-1

٦ الإجراء الأول: طلب واعتماد أداة أو حالة استخدام للذكاء الاصطناعي

مرجع بنود السياسة: QIS-4-1-1، QIS-2-4-1، QIS-9.2.2، QIS-9.1.2، QIS-9.1.1، ٦-٢-١

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
قائد الحوكمة والمخاطر والالتزام	عند كل طلب جديد	٨ خطوات	نحو ١٦ يوم عمل

٦٫١ الهدف

ضمان مرور كل أداة أو حالة استخدام مقترحة للذكاء الاصطناعي بمسار موحد للطلب والتقييم والاعتماد قبل استخدامها، وتوثيق قرار الاعتماد ومبرراته وأعلى تصنيف بيانات يجوز إدخاله.

٦٫٢ التكرار والنطاق

- عند طلب أي أداة أو نموذج ذكاء اصطناعي جديد للشركة.
- عند طلب استخدام الذكاء الاصطناعي في بيانات عميل أو إدخال ميزة ذكاء اصطناعي في نظامه.
- عند توسيع نطاق حالة استخدام قائمة أو تغيير الغرض منها.

٦٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	رفع طلب يتضمن الأداة والغرض والمستخدمين ونوع البيانات المتوقع إدخالها، والبديل غير التقني، والقيمة المتوقعة، وكلفة التشغيل.	الإدارة الطالبة اعتماد: المدير المباشر	الحوكمة والمخاطر	**نموذج الطلب**	يوم ٠
٢	الفحص الأولي للطلب والتحقق من اكتماله وتسجيله في سجل حالات الاستخدام.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	الإدارة الطالبة	**سجل حالات الاستخدام**	٣ أيام عمل
٣	تقييم المزود: موقع المعالجة والاستضافة، والاحتفاظ بالمدخلات، والتدريب عليها، والضوابط الأمنية، وشروط العقد.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	الرئيس التنفيذي للمالية	**تقييم المزود**	٥ أيام عمل

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	تقييم مخاطر الأمن السيبراني وفق الإجراء الثاني وتحديد مستوى التأثير.	العمليات والهندسة الأمنية اعتماد: قائد العمليات الأمنية	التقنية	**تقرير تقييم المخاطر**	بالتوازي
٥	المراجعة التقنية: الدخول الموحد، والمصادقة متعددة العوامل، والتسجيل، والتكامل.	الرئيس التنفيذي للتقنية اعتماد: الرئيس التنفيذي للتقنية	العمليات الأمنية	**توصية تقنية**	٣ أيام عمل
٦	الحصول على موافقة العميل المكتوبة إذا شمل الطلب بيانات عميل أو نظامه.	تقديم الخدمات اعتماد: رئيس تقديم الخدمات	العميل · الحوكمة	**موافقة العميل**	وفق العميل
٧	اتخاذ القرار: الاعتماد بشروط أو الرفض مع المبررات، واعتماد الحالات عالية التأثير من اللجنة الإشرافية.	الحوكمة والمخاطر اعتماد: اللجنة الإشرافية للحالات عالية التأثير	الإدارة الطالبة	**قرار موثق**	٥ أيام عمل
٨	إدراج الأداة في سجل الأدوات المعتمدة مع أعلى تصنيف بيانات مسموح، وإبلاغ الموظفين، وبدء مرحلة تجريبية محددة النطاق.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	جميع الإدارات	**سجل الأدوات المحدث**	يوم واحد

٦٫٤ ضوابط تنفيذية إلزامية

- لا تُستخدم أي أداة قبل إدراجها في سجل الأدوات المعتمدة.
- يُرفض الطلب الذي لا يمكن قياس أثره، أو الذي يقتصر مبرره على اقتناء أداة دون استخدام فعلي.
- لا تُستخدم بيانات أي عميل دون موافقته المكتوبة، وتُعالج داخل المملكة.
- يُحتفظ بقرار بشري نهائي في كل حالة يترتب عليها أثر على المواطنين.

٦٫٥ السجلات الواجب الاحتفاظ بها

نموذج الطلب، تقييم المزود، تقرير تقييم المخاطر، التوصية التقنية، موافقة العميل، القرار الموثق، سجل الأدوات المحدث.

٧ الإجراء الثاني: تقييم مخاطر الأمن السيبراني لأنظمة الذكاء الاصطناعي

مرجع بنود السياسة: ١-١-١، ١-١-٢، QIS-1-1-1 إلى QIS-1-1-3، ٢-٦-١ إلى ٢-٦-٣

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
العمليات والهندسة الأمنية	عند التغيير الجوهري / سنوياً	٧ خطوات	نحو ١٦ يوم عمل

٧,١ الهدف

تحديد مخاطر الأمن السيبراني المرتبطة بأدوات الذكاء الاصطناعي ومزاياه وتقييمها ومعالجتها ومتابعتها عبر جميع مراحل دورة الحياة، وفق منهجية QIS-RMM-001.

٧,٢ التكرار والنطاق

- قبل اعتماد أي أداة أو حالة استخدام جديدة.
- عند أي تغيير جوهري في النموذج أو مصدر البيانات أو نطاق الاستخدام.
- خلال اثني عشر شهراً من آخر تقييم كحد أقصى.
- فور اكتشاف ثغرة أو وقوع حادثة ذات علاقة.

٧,٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	تحديد نطاق التقييم ومكونات النظام والأصول والاعتماديات والعملاء المتأثرين.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	الحوكمة والمخاطر	**وثيقة النطاق**	يوم ٠
٢	تحليل التهديدات الخاصة بالذكاء الاصطناعي بمنهجية STRIDE: حقن الأوامر، وتسميم البيانات، واستخراج النماذج، وتسريب البيانات.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	التطوير	**سجل التهديدات**	٣ أيام عمل
٣	تقدير الاحتمالية والأثر وتحديد مستوى الخطر وفق المصفوفة في QIS-RMM-001.	العمليات الأمنية · الحوكمة اعتماد: قائد الحوكمة والمخاطر والالتزام	مالكو الأنظمة	**تقييم الخطر**	٣ أيام عمل

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	تحديد الضوابط المطلوبة وربطها بمالك ومدة تنفيذ.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	التقنية · التطوير	**خطة المعالجة**	٥ أيام عمل
٥	عرض المخاطر المتبقية على مالك الخطر للحصول على قبول موثق وفق صلاحيات القبول.	مالك الخطر اعتماد: حسب مستوى الخطر في QIS-RMM-001	اللجنة الإشرافية	**إقرار قبول المخاطر**	٥ أيام عمل
٦	تسجيل المخاطر في سجل المخاطر QIS-RR-001 ضمن فئة الذكاء الاصطناعي.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	اللجنة الإشرافية	**سجل المخاطر المحدث**	يوم واحد
٧	متابعة تنفيذ خطة المعالجة والتحقق من فاعليتها وتصعيد التأخير.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	اللجنة الإشرافية	**تقرير متابعة**	ربع سنوي

٧٫٤ ضوابط تنفيذية إلزامية

- يُعاد التقييم إلزامياً عند أي تغيير جوهري دون انتظار الدورة السنوية.
- تُعطَّل خصائص الذكاء الاصطناعي أو تُقيَّد عند اكتشاف ثغرة إلى حين التحقق من المعالجة.
- يُعد تجاوز مدة المعالجة المحددة حالة عدم امتثال تُصعَّد إلى مالك السياسة.
- لا يُطلق أي استخدام في نظام عميل قبل قبول المخاطر المتبقية.

٧٫٥ السجلات الواجب الاحتفاظ بها

وثيقة النطاق، سجل التهديدات، تقييم الخطر، خطة المعالجة، إقرارات قبول المخاطر، تقارير المتابعة.

٨ الإجراء الثالث: التطوير الآمن ومراجعة المخرجات والشيفرات المولدة

مرجع بنود السياسة: المكوّن ٢-١ كاملاً، QIS-1-2-1 إلى QIS-1-2-3، ٢-٧

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
الرئيس التنفيذي للتقنية	مع كل مشروع أو إصدار	٧ خطوات	دورة حياة المشروع

٨٫١ الهدف

ضمان تطبيق ممارسات التصميم الآمن في المشاريع التي تتضمن الذكاء الاصطناعي، ومراجعة الشيفرات والمخرجات المولدة بالذكاء الاصطناعي قبل استخدامها في أنظمة العملاء.

٨٫٢ التكرار والنطاق

- مشاريع العملاء التي تتضمن ميزة ذكاء اصطناعي في نطاقها.
- المشاريع التي تُستخدم فيها مساعدات البرمجة أو أدوات الذكاء الاصطناعي خلال التطوير.
- كل إصدار يغير نموذجاً أو أوامر أو مصادر معرفة لميزة قائمة.

٨٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	تحديد متطلبات الأمن السيبراني في مرحلة التخطيط وتضمينها في وثائق المشروع.	التطوير · العمليات الأمنية اعتماد: الرئيس التنفيذي للتقنية	تقديم الخدمات	**وثيقة المتطلبات**	قبل التطوير
٢	التحقق من مصادر البيانات وموثوقيتها، وتطبيق التحقق والتطهير على المدخلات الخارجية.	التطوير اعتماد: الرئيس التنفيذي للتقنية	الحوكمة والمخاطر	**تقرير مصادر البيانات**	مرحلة التحليل
٣	مراجعة الأقران والفحص الأمني وفحص الاعتماديات لكل شيفرة مولدة بالذكاء الاصطناعي في خط البناء.	التطوير اعتماد: قائد فريق التطوير	العمليات الأمنية	**نتائج الفحص**	قبل الدمج

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	تنفيذ اختبارات الأمن السيبراني وضوابط الحماية (Guardrails) للميزة والتحقق من فاعليتها.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	التطوير	**تقرير الاختبار**	قبل النشر
٥	بوابة مراجعة أمنية في نهاية كل مرحلة، وتوثيق قرار الموافقة أو الرفض ومبرراته.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	مدير المشروع	**قرار البوابة**	نهاية كل مرحلة
٦	الحصول على موافقة العميل المكتوبة على إدخال الميزة في نظامه.	تقديم الخدمات اعتماد: رئيس تقديم الخدمات	العميل	**موافقة العميل**	قبل النشر
٧	اعتماد النقل إلى بيئة الإنتاج وتوثيق ملف الانتقال وخطة التشغيل والرجوع.	الرئيس التنفيذي للتقنية اعتماد: الرئيس التنفيذي	اللجنة الإشرافية · العميل	**ملف الانتقال**	٥ أيام عمل

٨٫٤ ضوابط تنفيذية إلزامية

- لا تُدمج شيفرة مولدة بالذكاء الاصطناعي في مستودع عميل دون مراجعة وفحص.
- يُمنع استخدام بيانات العملاء الفعلية في بيئات التطوير إلا بعد إخفاء الهوية وموافقة العميل.
- يُمنع إعادة تدريب النماذج في بيئة التشغيل الفعلية دون ضوابط ومبررات موثقة.
- تُعامل البيانات المسترجعة من الأدوات وواجهات البرمجة الخارجية باعتبارها غير موثوقة.

٨٫٥ السجلات الواجب الاحتفاظ بها

وثيقة المتطلبات، تقرير مصادر البيانات، نتائج الفحص، تقارير الاختبار، قرارات البوابات، موافقة العميل، ملف الانتقال.

٩ الإجراء الرابع: إدارة الوصول والصلاحيات لأدوات الذكاء الاصطناعي

مرجع بنود السياسة: المكوّن ٢-٢ كاملاً، المكوّن ١-٣

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
الرئيس التنفيذي للتقنية	عند كل طلب صلاحية	٧ خطوات	نحو ٣ أيام عمل

٩,١ الهدف

ضمان اقتصار الوصول إلى أدوات الذكاء الاصطناعي ومكوناتها على المصرح لهم من المستخدمين والخدمات والوكلاء، وفق مبدأ الحد الأدنى من الصلاحيات.

٩,٢ التكرار والنطاق

- عند إنشاء حساب مستخدم أو حساب خدمة أو حساب وكيل ذكاء اصطناعي.
- عند تغيير الدور الوظيفي أو انتهاء العلاقة التعاقدية.
- المراجعة الدورية للهويات والصلاحيات والمفاتيح.

٩,٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	رفع طلب الصلاحية محدداً الأداة والمستوى والمبرر والمدة.	المدير المباشر اعتماد: مالك الأداة	—	**طلب الصلاحية**	عند الطلب
٢	التحقق من إكمال التدريب على السياسة، ومن الحاجة إلى المعرفة وفصل المهام.	مالك الأداة اعتماد: قائد العمليات الأمنية	الحوكمة والمخاطر	**موافقة موثقة**	يوم واحد
٣	منح الصلاحية عبر الدخول الموحد وتفعيل المصادقة متعددة العوامل.	التقنية اعتماد: الرئيس التنفيذي للتقنية	مالك الأداة	**إثبات التنفيذ**	يوم واحد
٤	ربط كل حساب وكيل ذكاء اصطناعي بمالك بشري مسؤول وتسجيله في سجل الأصول.	التطوير اعتماد: الرئيس التنفيذي للتقنية	العمليات الأمنية	**سجل الحسابات**	عند الإنشاء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٥	إدارة مفاتيح واجهات البرمجة في خزنة الأسرار: الإصدار والتدوير والإبطال الفوري عند الاشتباه.	التقنية اعتماد: الرئيس التنفيذي للتقنية	العمليات الأمنية	**سجل المفاتيح**	كل ٩٠ يوماً
٦	المراجعة الدورية للهويات والصلاحيات وحسابات الخدمة والمفاتيح.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	مالكو الأدوات · الحوكمة	**تقرير المراجعة**	ربع سنوي
٧	إلغاء جميع الصلاحيات فور انتهاء العلاقة التعاقدية أو تغيير الدور.	الموارد البشرية · التقنية اعتماد: الرئيس التنفيذي للمالية	العمليات الأمنية	**إثبات الإلغاء**	خلال ٢٤ ساعة

٩٫٤ ضوابط تنفيذية إلزامية

- يُمنع استخدام الحسابات المشتركة أو مجهولة المالك في أدوات الذكاء الاصطناعي.
- تُطبق حدود المعدل وحدود الاستخدام للتخفيف من مخاطر استخراج النماذج وتسريب البيانات.
- لا تُحذف سجلات الحسابات الملغاة، وتُحفظ وفق مدد الاحتفاظ المعتمدة.
- يُجرى المسح الأمني للعاملين ذوي الصلاحيات الحساسة على بيئات الذكاء الاصطناعي.

٩٫٥ السجلات الواجب الاحتفاظ بها

طلبات الصلاحيات والموافقات، سجل الحسابات، سجل المفاتيح، تقارير المراجعة الدورية، إثباتات الإلغاء.

١٠ الإجراء الخامس: الاستجابة لحوادث الذكاء الاصطناعي والإيقاف الآمن

مرجع بنود السياسة: المكوّن ٢-٨، ٣-١-١، QIS-3-1-2، QIS-3-1-1

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
العمليات والهندسة الأمنية	عند وقوع حادثة	٨ خطوات	احتواء خلال ٤ ساعات

١٠,١ الهدف

ضمان الكشف المبكر عن حوادث الأمن السيبراني المرتبطة بالذكاء الاصطناعي واحتوائها ومعالجتها والتعافي منها، وتوثيق الدروس المستفادة، ضمن خطة الاستجابة للحوادث QIS-IRP-001.

١٠,٢ التكرار والنطاق

- إدخال بيانات عميل أو بيانات شخصية في أداة غير معتمدة.
- تسريب بيانات عبر الأوامر أو المخرجات، أو حقن أوامر خبيثة.
- سلوك غير طبيعي في مخرجات ميزة ذكاء اصطناعي أو إجراءات وكيل في نظام عميل.
- تعطل ميزة ذكاء اصطناعي تدعم خدمة أساسية لعميل.

١٠,٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	رصد الحدث عبر مركز العمليات الأمنية المُدار أو بلاغ من الموظف أو العميل، وتسجيله.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	الحوكمة والمخاطر	**سجل الحادثة**	الساعة ٠
٢	تصنيف الخطورة وفق القسم ٥ من QIS-IRP-001.	قائد الحادثة اعتماد: قائد الحادثة	الرئيس التنفيذي للتقنية	**تقييم الخطورة**	خلال ساعة
٣	الاحتواء: تعطيل الميزة أو تقييدها، وإلغاء المفاتيح والجلسات المتأثرة، وحفظ الأدلة.	العمليات الأمنية · التقنية اعتماد: قائد الحادثة	التطوير	**إجراءات الاحتواء**	خلال ٤ ساعات

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	إبلاغ العميل المتأثر، وإبلاغ جهة التحكم بأي تسرب لبيانات شخصية لتتمكن من إبلاغ سدايا خلال ٧٢ ساعة.	تقديم الخدمات · مسؤول حماية البيانات اعتماد: قائد الحادثة	الرئيس التنفيذي	**إشعارات موثقة**	وفق QIS-IRP-001
٥	الرجوع إلى آخر إصدار معتمد أو الإيقاف الآمن وتفعيل البديل اليدوي عند الحاجة.	التقنية اعتماد: الرئيس التنفيذي للتقنية	تقديم الخدمات	**سجل الاستعادة**	وفق زمن التعافي
٦	إزالة السبب الجذري واختبار المعالجة قبل إعادة التشغيل.	التطوير · العمليات الأمنية اعتماد: قائد العمليات الأمنية	الحوكمة والمخاطر	**تقرير المعالجة**	٥ أيام عمل
٧	إعادة تقييم المخاطر وفق الإجراء الثاني وتحديث سجل المخاطر.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	اللجنة الإشرافية	**سجل المخاطر المحدث**	٥ أيام عمل
٨	جلسة الدروس المستفادة وإغلاق الحادثة.	قائد الحادثة اعتماد: قائد الحادثة	اللجنة الإشرافية	**تقرير الإغلاق**	١٠ أيام عمل

١٠٫٤ ضوابط تنفيذية إلزامية

- تُحفظ الأدلة قبل أي إجراء يؤدي إلى إتلافها.
- لا يُعاد تشغيل الميزة قبل التحقق من المعالجة واعتماد الإعادة.
- يُعد إدخال بيانات العملاء في أداة غير معتمدة حادثة بيانات تُبلَّغ وفق مهلها.
- تُحفظ سجلات الحادثة اثني عشر شهراً على الأقل.

١٠٫٥ السجلات الواجب الاحتفاظ بها

سجل الحادثة، تقييم الخطورة، سجل الاحتواء والأدلة، الإشعارات، سجل الاستعادة، تقرير المعالجة، تقرير الإغلاق.

١١. متطلبات تمكين وتنفيذ الإجراءات

١١٫١ الأنظمة والأدوات المطلوبة

الأداة / النظام	الغرض	الإجراءات
سجل الأدوات المعتمدة وحالات الاستخدام	تسجيل الطلبات والقرارات والتصنيف المسموح لكل أداة	١، ٢
سجل المخاطر QIS-RR-001	تسجيل مخاطر الذكاء الاصطناعي ومتابعة معالجتها	٢، ٥
خط البناء مع أدوات الفحص الأمني وفحص الاعتماديات	فحص الشيفرات المولدة قبل الدمج	٣
الدخول الموحد وخزنة الأسرار	إدارة الهويات والمفاتيح	٤
منع تسرب البيانات وقائمة السماح بالوجهات	منع إرسال البيانات إلى خدمات غير معتمدة	١، ٥
مركز العمليات الأمنية المُدار	رصد السجلات والحوادث	٥

١١٫٢ مصفوفة الموافقات

القرار	المعتمِد
اعتماد أداة لا تُدخل فيها بيانات عملاء	قائد الحوكمة والمخاطر والالتزام مع الرئيس التنفيذي للتقنية
اعتماد استخدام الذكاء الاصطناعي في بيانات عميل	اللجنة الإشرافية، بعد موافقة العميل المكتوبة
إدخال ميزة ذكاء اصطناعي في نظام عميل	الرئيس التنفيذي، بعد موافقة العميل المكتوبة
قبول المخاطر المتبقية	حسب مستوى الخطر وفق صلاحيات القبول في QIS-RMM-001
إعادة تشغيل ميزة بعد حادثة	قائد الحادثة مع الرئيس التنفيذي للتقنية

١٢. مؤشرات قياس الالتزام

الرمز	المؤشر	المستهدف	الإجراء
PRC-01	نسبة الطلبات التي أُنجزت ضمن المدة المرجعية للإجراء الأول	٩٠٪	١

الرمز	المؤشر	المستهدف	الإجراء
PRC-02	نسبة أدوات الذكاء الاصطناعي ذات تقييم مخاطر ساري المفعول	٪١٠٠	٢
PRC-03	نسبة الشيفرات المولدة التي اجتازت الفحص قبل الدمج	٪١٠٠	٣
PRC-04	نسبة الصلاحيات الملغاة خلال ٢٤ ساعة من انتهاء العلاقة	٪١٠٠	٤
PRC-05	نسبة حوادث الذكاء الاصطناعي المحتواة خلال ٤ ساعات	٪٩٥	٥

١٣. المراجع

النوع	رمز المرجع	اسم المرجع
داخلي	QIS-POL-002	سياسة استخدام الذكاء الاصطناعي (السياسة الأم)
داخلي	QIS-RMM-001	منهجية إدارة المخاطر
داخلي	QIS-RR-001	سجل المخاطر
داخلي	QIS-IRP-001	خطة الاستجابة للحوادث السيبرانية
داخلي	QIS-BCP-001	خطة استمرارية الأعمال
خارجي	AICG-1:2026	إرشادات الأمن السيبراني للذكاء الاصطناعي — الهيئة الوطنية للأمن السيبراني
خارجي	PDPL	نظام حماية البيانات الشخصية ولائحته التنفيذية